



György Istókovichs <istokovicsgyorgy79@gmail.com>

Fwd: Case ID: VRF#26-09-MTNJR- FORMAL NOTICE: Intentional Architectural Deception and Professional Malpractice

1 üzenet

György Istókovichs <istokovicsgyorgy79@gmail.com>

2026. szeptember 16. 2:46

Címzett: cvd@cisa.dhs.gov

The previous CMU SEI CERT/CC team declined to coordinate my global sensitive data exposure case (CWE-459: Incomplete Cleanup) and closed my report under Case ID: VRF#26-09-MTNJR by uncritically deferring to Google's claim of an "intended vendor decision."

As CISA is now assuming direct management of coordinated vulnerability disclosure through VINCE-NT, I respectfully request that CISA review the procedural dismissal by the previous coordination team and transition this case into the new VINCE-NT platform.

This issue involves an active architectural failure within a global AI infrastructure (Google AI Studio / Interactions API) where user-deleted session contexts and sensitive prompts persist indefinitely on production backend storage, directly contradicting the vendor's documented 24-hour TTL auto-purge specifications.

----- Forwarded message -----

Feladó: **György Istókovichs** <istokovicsgyorgy79@gmail.com>

Date: 2026. szept. 15., K, 21:05

Subject: Re: Case ID: VRF#26-09-MTNJR- FORMAL NOTICE: Intentional Architectural Deception and Professional Malpractice

To: <cert@cert.org>, <vince@cert.org>

AMENDMENT REGARDING GOOGLE'S INTERNAL BOT INFRASTRUCTURE:

The Google IssueTracker triage bot is explicitly a non-official, automated front-line filtering mechanism designed to automatically dismiss technical compliance reports. A triage bot script writing "Won't Fix" and generating automated responses cannot legally or technically be recognized as an official corporate statement or an approved corporate position.

Google is fully aware of this architecture. They use this automated bot framework intentionally to stonewall researchers and cover up the fact that their live backend contradicts their official public specifications. You cannot treat a corporate triage script as an authoritative architectural decision while completely ignoring the vendor's legally binding public documentation and user-facing UI promises.

György Istókovichs <istokovicsgyorgy79@gmail.com> ezt írta (időpont: 2026. szept. 15., K, 20:54):

REGULATORY NON-COMPLIANCE AND BREACH OF SERVICE LEVEL AGREEMENT (SLA):

Your own official coordination policy explicitly states that during the decision-making process for coordination, you strictly evaluate whether "the vendor or maintainer has not responded in a reasonable amount of time, or has stopped communicating." In my case, this condition is 100% fulfilled because Google has never officially responded. An automated IssueTracker bot triage script cannot be legally or technically considered an official corporate response. Google responded via an automated script—proving that no human engineer reviewed, vetted, or closed my issue on IssueTracker.

Furthermore, your policy states you evaluate whether "the vulnerability is likely to cause widespread, national, or global damage." Google AI Studio is a global infrastructure;

therefore, this persistent server-side data retention constitutes a global security and privacy risk. There is absolutely no clause in your official guidelines stating that if a vendor arbitrarily labels a critical defect as "Intended Behavior," you are forbidden from investigating it.

Google's own official Gemini API documentation explicitly states an entirely different behavior regarding data deletion and TTL expiration rules. Moreover, the actual buttons and text labels on the Google AI Studio user interface (UI) explicitly promise permanent, unrecoverable erasure, which directly contradicts the hidden backend reality I have forensically demonstrated.

Regarding your 3-day Service Level Agreement (SLA): your documentation explicitly guarantees that "Vendors and reporters can expect a response from CERT/CC within three days." Despite this formal commitment, my case was summarily dismissed and closed almost instantly via an automated template letter, without any substantive human engineering review or technical analysis. This constitutes a severe and direct breach of your own published Service Level Agreement (SLA).

Finally, your documentation formally acknowledges external messaging protocols: "you can still email us at cert@cert.org. Please continue to use the appropriate tracking number (such as VU#, VRF#) in the subject line of any email sent to us." Therefore, the formal pre-litigation notice I submitted under Case ID: VRF#26-09-MTNJR is fully valid according to your own procedural rules, and your legal compliance department is strictly required to archive and document it within my active file.

György Istókovichs <istokovicsgyorgy79@gmail.com> ezt írta (időpont: 2026. szept. 15., K, 20:30):

FORMAL NOTICE: Intentional Architectural Deception and Professional Malpractice regarding Data Deletion (Case ID: VRF#26-09-MTNJR) To the CERT/CC Coordination Team / Google LLC Legal & Security Department, I am filing this formal notice regarding the systemic and intentional data retention fraud currently labeled as "Intended Behavior" within your systems. 1. Admission of Intentional Deception By officially labeling the persistence of user-deleted data as "Intended Behavior," your engineering and security teams have formally conceded that the "Delete" function in Google AI Studio and the Google Drive Trash is a deliberate visual deception (Placebo Deletion). You have knowingly engineered a system where the UI promises irreversible destruction, while the backend architecture is configured to retain the session state to bypass these user commands. 2. Engineering Malpractice This is not a software bug or an oversight; it is an architectural decision made by your engineering teams. As technical professionals, your engineers are fully aware that a .json file in Google Drive is merely an interface pointer, and that the conversation context, tokens, and system prompts reside on persistent backend servers (Interactions API). By failing to trigger a cascade-delete signal to the backend upon the user's "Delete" command, your engineers have consciously designed a system that bypasses its own documented 24-hour TTL purge. It is professional malpractice to knowingly operate a system that violates its own published specifications (1-day TTL) and misleads the end-user regarding the permanency of data deletion. 3. Formal Legal Warning The continued suppression of these findings via automated "Duplicate" closures, coupled with the intentional retention of sensitive user prompts, is not merely a technical issue—it is a compliance fraud. I am hereby putting you on formal notice: I am actively preparing civil litigation against Google LLC and its involved entities. Furthermore, I am prepared to hold the oversight bodies accountable for their administrative evasion and failure to perform a substantive, human review of the provided forensic dossier. Your "Intended Behavior" label is a written confession of this systemic fraud. I demand a substantive, human legal response acknowledging the failure to enforce the documented TTL purge. OFFICIAL REBUTTAL AND PRE-LITIGATION NOTICE: It is completely obvious that neither data privacy nor technical software integrity interests you. This entire coordination process is a protective farce designed to shield Big Tech infrastructure from liability. You are intentionally ignoring the official, public developer documentation provided by the vendor. When a public specification explicitly promises automatic data destruction via TTL rules, but the actual implementation fails to execute a DELETE or DROP command—leaving sensitive tokens and prompts active on production storage indefinitely—it is by definition a critical software vulnerability, not a standard "business decision." By relying on the automated response of a Google IssueTracker bot to summarily close this investigation, you are actively participating in the deliberate misrepresentation and cover-up of this backend fraud. Take official notice that I am currently consulting with legal counsel. I am seriously considering filing a formal lawsuit in the European courts, where I will sue

Google LLC and the CERT Coordination Center jointly as co-defendants for negligence, bad-faith handling, and systemic non-compliance. Review this file manually with a human engineer immediately, or face the legal consequences in court. György Istókovics Independent Security Researcher istokovicsgyorgy79@gmail.com

 **VINCE.pdf**
347K